4. Cvičenie

1. Cieľ cvičenia

Cieľom cvičenia je pochopiť a aplikovať základnú logiku posudzovania rizík kybernetickej bezpečnosti v organizácii, teda ako sa k identifikovaným primárnym aktívam a k nim priradeným podporným aktívam postupne identifikujú hrozby, zraniteľnosti a následne sa hodnotí riziko.

V predchádzajúcich cvičeniach ste postupne:

- definovali modelovú organizáciu a jej procesy,
- identifikovali najdôležitejšiu službu organizácie,
- rozložili službu na procesy a identifikovali primárne a podporné aktíva,
- identifikovali informačné aktíva a klasifikovali ich podľa princípov CIA (Confidentiality, Integrity, Availability),
- posúdili, či organizácia patrí medzi prevádzkovateľov základnej služby podľa zákona č. 69/2018 Z. z.

V tomto cvičení budete na tieto výstupy nadväzovať a využijete ich ako vstupné údaje pre posudzovanie rizík kybernetickej bezpečnosti. Pozor, je treba si uvedomiť, že cieľom cvičenia nie je identifikovať všetky možné riziká, ale pochopiť logiku ich identifikácie a hodnotenia!

Pri spracovaní budete vychádzať najmä z (obsiahnuté v prednáške prof. Lovečka):

- ISO/IEC 27005 – Information Security Risk Management,
- metodických prístupov používaných v oblasti kybernetickej bezpečnosti,
- zákona č. 69/2018 Z. z. o kybernetickej bezpečnosti, najmä § 19 a § 20.

2. Terminologický rámec

Pri posudzovaní rizík sa pracuje s niekoľkými základnými pojmami, ako:

Aktívum: predstavuje hodnotu pre organizáciu, ktorá je potrebná na poskytovanie služby a ktorú je potrebné chrániť. Aktíva sa v tejto oblasti rizík delia na:

- primárne aktíva
- podporné aktíva

Primárne (prevádzkové) aktíva

Tieto aktíva tvoria jadro činnosti organizácie. Patria sem:

- Informácie: Sú to **samotné dáta a vedomosti** v rôznych formách (napr. databázy, dokumenty, duševné vlastníctvo – to kde sa uchovávajú sú už podporné aktíva).

- Obchodné procesy a činnosti: Postupy, ktoré organizácia vykonáva, aby poskytovala svoje služby (napr. fakturácia, diagnostika pacienta, dispečing, vzdelávanie, výskum,...)

Narušenie primárnych aktív má priamy dopad na poskytovanie služby organizácie.

Podporné aktíva

Podporné aktíva predstavujú prostriedky, ktoré umožňujú fungovanie primárnych aktív. Zahŕňajú:

- **Hardvér a sieťová infraštruktúra**: Servery, koncové zariadenia, komunikačné linky.
- **Softvér:** Operačné systémy, aplikačné programy a databázové systémy.
- **Ľudia:** Zamestnanci a tímy s ich znalosťami, kvalifikáciami a skúsenosťami.
- **Lokalita:** Fyzické priestory ako kancelárie, serverovne alebo dátové centrá.
- **Externé služby:** Cloudové riešenia, outsourcing alebo telekomunikačné služby.

Narušenie podporných aktív môže nepriamo **ovplyvniť primárne aktíva** a poskytovanie služby.

Informačné aktíva

Informačné aktíva sú v kontexte kybernetickej bezpečnosti definované ako znalosti alebo údaje, ktoré majú pre jednotlivca alebo organizáciu určitú hodnotu. Predstavujú všetky informácie alebo údaje, ktoré organizácia spracúva a potrebuje chrániť.

V Cvičení 2 ste tieto informácie klasifikovali podľa princípov:

- Confidentiality – dôvernosť
- Integrity – integrita
- Availability – dostupnosť

Táto klasifikácia určuje význam a citlivosť informačných aktív. Pri posudzovaní rizík je tento význam dôležitý pre určenie dopadu možného bezpečnostného incidentu.

Vo všeobecnosti platí:

- aktíva s vyššou CIA klasifikáciou majú pri narušení vyšší dopad,
- aktíva s nižšou klasifikáciou majú nižší dopad.

Príklad: databáza obsahuje citlivé informácie a bola klasifikovaná s vysokou dôvernosťou, dopad takéhoto incidentu by bol vysoký. Môže ísť napríklad o únik osobných údajov, reputačnú škodu alebo právne dôsledky.

Hrozba

Hrozba je potenciálna udalosť alebo činnosť, ktorá môže spôsobiť narušenie bezpečnosti aktíva.

Príklady hrozieb:

- kybernetický útok,
- malware alebo ransomware,...

Pri identifikácii hrozieb môžete využiť napríklad metodické materiály Národného bezpečnostného úradu:

Katalóg hrozieb

Zraniteľnosť

Zraniteľnosť predstavuje slabé miesto systému alebo organizácie, ktoré môže umožniť realizáciu hrozby.

Príklady:

- slabé heslá,
- chýbajúce aktualizácie systému,
- nedostatočné zálohovanie,
- nedostatočná kontrola prístupov
- zle navrhnutý proces (ako sa má vykonávať napr. činnosť úhrada faktúr)

Riziko

Riziko predstavuje možnosť, že hrozba využije zraniteľnosť aktíva a spôsobí negatívny dopad (následok) na organizáciu alebo na poskytovanie jej služby.

(Logiku vzniku rizika) Viac o riadení rizík a metodiku analýzy rizík môžete nájsť aj na:

- https://www.nbu.gov.sk/riadenie-rizik/
- https://www.nbu.gov.sk/data/att/3446.pdf

---

3. Úlohy zadania

V tejto časti budete postupovať podľa základnej logiky posudzovania rizík:

Aktívum (primárne-podporné aktíva) - hrozba – zraniteľnosť - rizikový scenár - dopad - pravdepodobnosť - úroveň rizika

Cieľom je pochopiť, ako sa z identifikovaných primárnych aktív a k ním priradených podporných aktív postupne identifikujú zraniteľnosti a hodnotí riziko.

Úloha 1 – Stanovenie kritérií hodnotenia rizík

Pred samotným hodnotením rizík je potrebné stanoviť kritériá, podľa ktorých bude organizácia riziká posudzovať.

Pri hodnotení dopadu zohľadnite najmä tieto oblasti:

- narušenie dôvernosti informácií (Confidentiality)
- narušenie integrity informácií (Integrity)
- narušenie dostupnosti služby (Availability)

- finančný dopad
- právny dopad
- reputačný dopad
- dopad na zákazníkov alebo verejnosť

Pri určovaní dopadu vychádzajte aj z CIA klasifikácie informačných aktív, ktorú ste vykonali v Cvičení 2.

Stupnica dopadu (pozrite sa do metodiky na NBU – sú rôzne prístupy, definovanie, je to na organizácií, ona si stanovuje kritéria ale musí mať aj konverznú tabuľku - mapovanie medzi internou stupnicou a oficiálnou stupnicou. Aby vedela preukázať súlad s legislatívou.)

Hodnota	**Úroveň dopadu**	**Charakteristika**
1	zanedbateľný	minimálny dopad na prevádzku organizácie, krátkodobé a ľahko riešiteľné narušenie služby bez významného vplyvu na používateľov
2	nízky	mierne prevádzkové komplikácie, obmedzený dopad na časť používateľov alebo krátkodobé narušenie dostupnosti služby
3	stredný	významné narušenie služby alebo procesov organizácie, citeľný dopad na používateľov alebo interné fungovanie organizácie
4	vysoký	dlhší výpadok služby alebo vážne narušenie prevádzky, významný finančný, právny alebo reputačný dopad
5	kritický	úplné prerušenie poskytovania služby alebo závažné dopady na organizáciu, zákazníkov alebo verejnosť (napr. únik citlivých údajov alebo rozsiahly výpadok služby)

Stupnica pravdepodobnosti

Pravdepodobnosť vyjadruje, ako často alebo ako reálne môže dôjsť k realizácii hrozby, ktorá využije zraniteľnosť aktíva.

Hodnota	**Pravdepodobnosť**	**Charakteristika**
1	veľmi nízka	realizácia hrozby je veľmi nepravdepodobná, môže sa vyskytnúť len vo výnimočných prípadoch
2	nízka	realizácia hrozby je možná, ale očakáva sa skôr zriedkavo
3	stredná	realizácia hrozby je reálne možná a môže sa vyskytnúť v bežnej prevádzke organizácie

4	vysoká	realizácia hrozby je pravdepodobná a môže sa vyskytnúť opakovane
5	veľmi vysoká	realizácia hrozby je takmer istá alebo sa už v organizácii či sektore opakovane vyskytla

Výpočet rizika

Úroveň rizika určte podľa vzťahu:

Riziko = Dopad × Pravdepodobnosť

Matica výpočtu rizika (Dopad × Pravdepodobnosť)

Dopad \ Pravdepodobnosť	1 – veľmi nízka	2 – nízka	3 – stredná	4 – vysoká	5 – veľmi vysoká
5 – kritický dopad	5	10	15	20	25
4 – vysoký dopad	4	8	12	16	20
3 – stredný dopad	3	6	9	12	15
2 – nízky dopad	2	4	6	8	10
1 – zanedbateľný dopad	1	2	3	4	5

Kritériá akceptácie rizika

Na základe vypočítanej úrovne rizika organizácia rozhoduje, či je riziko akceptovateľné alebo je potrebné prijať bezpečnostné opatrenia.

Hodnota rizika	**Úroveň rizika**	**Charakteristika**	**Postup organizácie**
1 – 5	**nízke riziko**	riziko má minimálny dopad na organizáciu	riziko je akceptovateľné, nie je potrebné prijímať dodatočné opatrenia
6 – 10	**stredné riziko**	riziko môže spôsobiť prevádzkové komplikácie	riziko je možné akceptovať, odporúča sa jeho sledovanie alebo zváženie opatrení
11 – 15	**zvýšené riziko**	riziko môže významne ovplyvniť prevádzku organizácie	odporúča sa prijať opatrenia na zníženie rizika

16 – 25	**vysoké riziko**	riziko môže spôsobiť vážne narušenie služby alebo organizácie	riziko je neakceptovateľné, je potrebné prijať bezpečnostné opatrenia

Vytvorte si kritéria na hodnotenie aktív, môžete použiť tie vyššie alebo si ich prispôsobte organizácií!

Úloha 2 – Výber aktív

Pri výbere aktív rozlišujte medzi:

- primárnymi aktívami (napr. informačné aktíva alebo procesy, služby),
- podpornými aktívami (napr. systémy, infraštruktúra, ľudia alebo externé služby).

Na základe výstupov z Cvičenia 2 vyberte minimálne 5 podporných aktív, ktoré sú kľúčové pre poskytovanie služby organizácie, ktorú ste si identifikovali, ak ich máte viac, vyberte si iba jednu.

Úloha 3 – Identifikácia hrozieb a zraniteľností

Pre každé vybrané aktívum identifikujte:

- minimálne 2 hrozby,
- minimálne 3 zraniteľnosti.

Na základe týchto prvkov vytvorte rizikový scenár.

Úloha 4 – Register rizík

Register rizík služby

Na základe identifikovaných podporných aktív vytvorte rizikové scenáre. Každý riadok tabuľky predstavuje jeden rizikový scenár. Rizikový scenár je opis situácie, v ktorej sa konkrétna hrozba môže realizovať prostredníctvom existujúcej zraniteľnosti a spôsobiť dopad na aktívum organizácie. Pre hrozby sa inšpirujte v katalógu z NBU a skúste vyhľadať aj katalógy zraniteľnosti.

	Primárne aktívum 1					
Podporné aktívum	**Hrozba**	**Zraniteľnosť**	**CIA**	**Dopad**	**Pravdepodobnosť**	**Riziko**
Databázový server	Neoprávnený prístup útočníka	Slabé heslo administrátora	C	5	3	15
...						

Postup pri vyplňovaní tabuľky

1. Podporné aktívum
   Identifikujte podporné aktívum, ktoré umožňuje poskytovanie služby (napr. informačný systém, databázový server, sieťová infraštruktúra, zamestnanec, externá služba).

2. Hrozba
   Uveďte potenciálnu udalosť, ktorá môže narušiť bezpečnosť aktíva (napr. kybernetický útok, malware, výpadok služby, chyba používateľa).

3. Zraniteľnosť
   Identifikujte slabé miesto, ktoré môže umožniť realizáciu hrozby (napr. slabé heslá, neaktualizovaný systém, nedostatočné školenie zamestnancov).

4. CIA
   Uveďte, ktoré princípy informačnej bezpečnosti sú najviac ohrozené:

   - C – Confidentiality (dôvernosť)
   - I – Integrity (integrita)
   - A – Availability (dostupnosť)

5. Dopad
   Určte dopad realizácie scenára na organizáciu podľa stanovenej stupnice.

6. Pravdepodobnosť
   Odhadnite pravdepodobnosť realizácie scenára (aktívum, hrozba, zraniteľnosť), v bežnej praxi sa to nazýva aj pravdepodobnosť udalosti/incidentu.

7. Riziko
   Hodnota rizika sa určí ako (tabuľka s kritériami):

$$Riziko = Dopad \times Pravdepodobnosť$$

Úloha 5 – Matica rizík

Na základe výsledkov vytvorte maticu rizík (5 × 5) a zakreslite do nej identifikované riziká. Matica musí umožniť rozlíšiť:

- nízke riziká,
- stredné riziká,
- vysoké riziká.

6. Úloha - Otázky na doplnenie k registru rizík

Pozrite sa na tabuľku registra rizík, ktorú ste vytvorili vyššie. Zamyslite sa nad tým, či tabuľka obsahuje všetky informácie, ktoré by organizácia potrebovala na riadenie rizík v praxi.

Odpovedzte na nasledujúce otázky:

1. Ktoré ďalšie informácie alebo stĺpce by bolo vhodné do tabuľky registra rizík doplniť?
2. Prečo by tieto informácie boli pre organizáciu dôležité pri riadení rizík?
3. Ako by tieto doplnené informácie pomohli organizácii pri prijímaní bezpečnostných opatrení alebo pri riadení bezpečnosti?

Výstup z cvičenia (tie podporné informácie nedávajte do práce, ktorú pripravujete)

- kritériá hodnotenia rizík,
- identifikované primárne a podporné aktíva,
- register rizík,
- maticu rizík.
- odpovede na otázky

Cieľom výstupu je preukázať pochopenie procesu posudzovania rizík kybernetickej bezpečnosti v organizácii.